



ADR-007: Authentication — local JWT + TOTP now; OIDC federation to the TASCO IdP as target

TASCO Insurance × VETC Growth Platform — Architecture Decision Record

iorta TechNXT

Version 1.0 · 07 October 2026

Contents

Context and problem statement

Decision drivers

Considered options

Decision outcome

Pros and cons of the options

Document	Version	Date	Owner	Status
ADR-007	1.0	07 October 2026	iorta TechNXT Architecture	Accepted (interim for pilot and UAT; target state defined)

- **Related:** [Security Architecture](#), sections 7–8 and 15

Context and problem statement

Four kinds of principal call the platform:

1. **Staff** (13 roles) from TASCO and VETC, using the console;
2. **Customers** inside the VETC app or Zalo mini app;
3. **Partner systems**, server to server;
4. **Batch jobs**.

The TASCO enterprise IdP (Azure AD / Keycloak) and VETC app SSO cannot be integrated in the pilot timeframe. MFA is still required for privileged roles, and joiner-mover-leaver must be controlled.

Decision drivers

- MFA for privileged roles from day one.
- The principal contract `{id, roles, region, customerId?}` must not change when the IdP arrives.
- Short-lived tokens; lockout against brute force.
- Partners get revocable machine credentials.

Considered options

1. **Local users (scrypt) + TOTP + short-lived HS256 JWT now. Target: OIDC with the TASCO IdP for staff, token exchange with VETC SSO for customers, and API keys moving to OAuth2 client credentials or mTLS for partners.**
2. Integrate the IdP before the pilot.
3. Server-side sessions with cookies.

Decision outcome

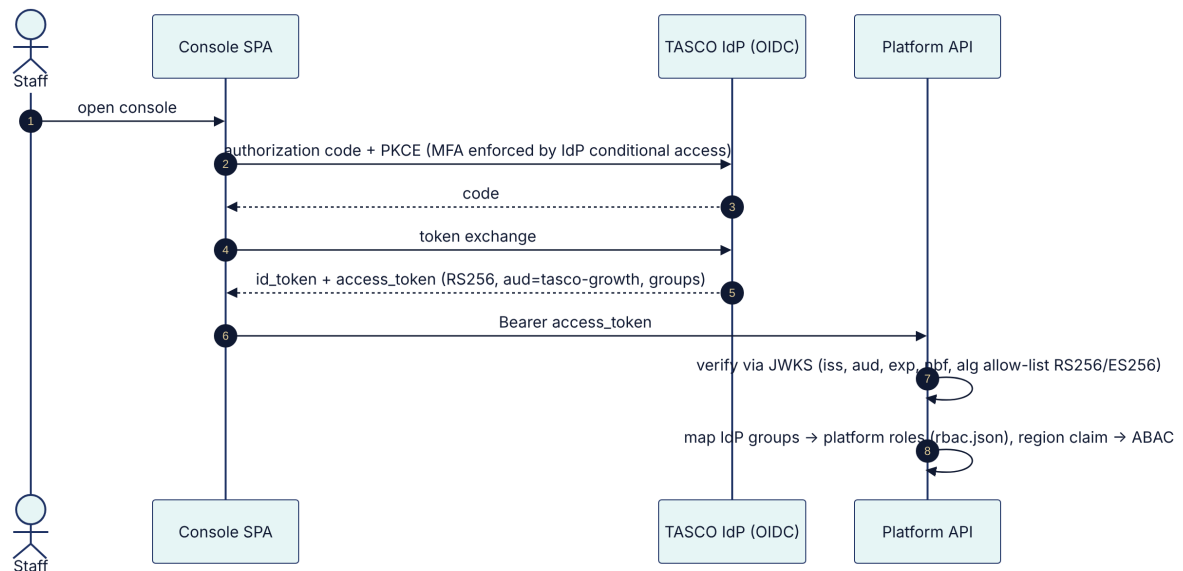
Chosen option: **1.**

Current implementation

Principal	Mechanism	Code
Staff	Username + password (scrypt N=16384, r=8, p=1, 16 B salt, 64 B hash) → if the role is in MFA_REQUIRED_ROLES (default admin, rule_approver, compliance_officer, data_steward) or the user is enrolled → mfaToken (JWT aud=mfa, 5 min) → TOTP (RFC 6238, SHA-1, 6 digits, ±1 step) → access JWT (aud=staff, amr, jti, TTL JWT_TTL_SECONDS = 1,800 s)	identityService.js, crypto.js

Principal	Mechanism	Code
MFA self-enrolment	A privileged user without an enrolled authenticator receives a fresh seed at first sign-in (QR code / otpauth URI), shown only to that user after the password step; enrolment completes with the first valid code (<code>auth.mfa_enrolled</code>). Administrators never see seeds; <code>POST /api/users/:id/reset {resetMfa}</code> forces re-enrolment.	<code>identityService.login, verifyMfa, reset</code>
Replay protection	The last accepted TOTP time step is stored (<code>lastTotpStep</code>); a code at or before it is rejected (ASVS 2.8.4).	<code>identityService.verifyMfa</code>
First sign-in	Users created by an administrator must change their password at first sign-in (<code>mustChangePassword</code>).	<code>identityService</code>
Lockout	5 failures (<code>LOCKOUT_MAX_FAILURES</code>) → locked for 15 min (<code>LOCKOUT_MINUTES</code>), counting both password and TOTP failures; the lock is checked at both steps. Failures are audited. Unknown users get a timing-equalised response. <code>POST /api/users/:id/reset {unlock}</code> for the service desk (not for one's own account).	<code>identityService.login, verifyMfa</code>
Per-request	<code>verifyJwt</code> pins <code>alg=HS256</code> , uses a constant-time signature comparison and checks <code>exp</code> . The user is reloaded on every request. Tokens issued before <code>tokensValidAfter</code> (set on password change, MFA reset, and role, status or region change) are rejected. The <code>jti</code> logout list is also checked.	<code>identityService.authenticate</code>
Customer	A signed renewal link (<code><profileId>.<expiry>.<MAC></code> , valid for <code>LINK_TTL_DAYS</code> , default 30) or, only in <code>DEMO_MODE</code> , a profile id → customer JWT <code>aud=customer</code> , 1 h. Erased data subjects lose their sessions. Target: VETC SSO token exchange.	<code>routes.js /api/customer/session, customerService.issueCustomerToken</code>
Partner	<code>X-API-Key: tpk_<24 random bytes></code> . Only the SHA-256 is stored, with a prefix for support. Revocable. The partner must be active. Key scopes (<code>quote, purchase, policies:read</code>) are enforced per route.	<code>partnerService, app.js</code>
Password policy	12–128 characters (ASVS V2.1, length over complexity)	<code>checkPasswordPolicy</code>

Target state (phase 2)



- Customers: the VETC app exchanges its SSO token for a platform customer token (RFC 8693 token exchange or a signed assertion). Only customers can pay; wallet debits follow VETC's in-app confirmation.
- Partners: OAuth2 client credentials carrying the same scopes, or mTLS at the gateway. API keys are retained only for small partners.

Consequences

- Good: privileged roles are MFA-protected today with self-enrolment (no administrator ever handles a seed) and replay protection, and the principal contract is stable across the migration.
- Good: there is no session state on the server. Tokens are short-lived.
- Bad / gaps:
 - HS256 uses one shared secret (`JWT_SECRET`) for staff, customer and MFA tokens; they are separated only by `aud` . Any holder of the secret can mint any token. The target is asymmetric RS256/ES256 from the IdP.
 - **The logout list is in-process, per replica.** Logout is only guaranteed on the replica that handled it, until the token expires (≤ 30 min). Credential, role and status changes are not affected, because `tokensValidAfter` is persisted. The target is a shared denylist (Redis) or IdP session revocation.
 - The `mfaToken` is not single-use within its 5-minute life; the lockout and TOTP replay protection limit the impact. **Fix:** bind it to a single-use nonce.
 - Renewal links embed the plate key and are reusable until they expire. **Fix:** a nonce and a pseudonymous id.
 - `GET /api/demo/totp/:username` returns live TOTP codes when `DEMO_MODE` is on. `DEMO_MODE` is opt-in (default `false`) and refused in production; only the hosted UAT, with synthetic data, enables it.
- Resolved since the first issue: lock check in `verifyMfa` , TOTP replay protection, token revocation on password change, link expiry, partner scope enforcement, and administrator access to TOTP seeds (replaced by self-enrolment).

Pros and cons of the options

IdP first. The best end state. However, it would block the pilot on enterprise onboarding lead time.

Cookie sessions. Revocation is easy. However, they need sticky or shared session storage plus CSRF protections, and they suit partners and app embedding less well.